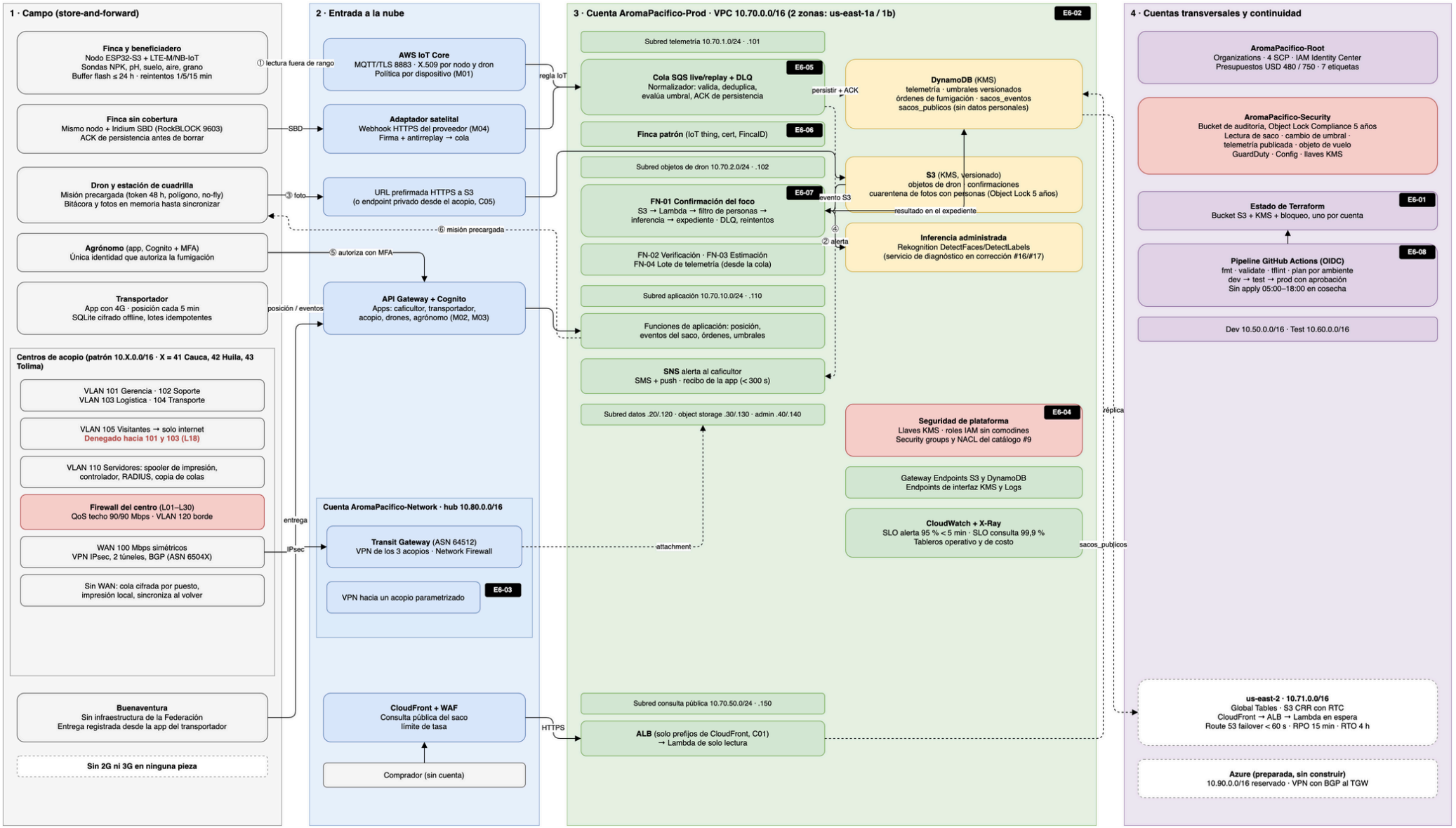
Arquitectura de AromaPacífico

Documento consolidado de la actualización del piloto cafetero de 2020: los siete puntos del reto en un solo lugar, con el diagrama completo. Cada sección resume la decisión y enlaza al documento de detalle, donde están los cálculos, las tablas completas y las fuentes.

Es un caso académico inspirado en la Federación Nacional de Cafeteros; no es un proyecto oficial de la Federación.

1. Vista general



Fuente editable: vista-general.drawio.

El piloto conecta **200 fincas** de Cauca, Huila y Tolima, **60 transportadores**, **tres centros de acopio** y la entrega del saco de 60 kg en **Buenaventura**. La plataforma vive en **AWS, región** `us-east-1`. `us-east-2` es la región de contingencia de la consulta pública del saco, y **Azure** queda preparada como segunda nube sin construir nada en ella.

El diagrama se lee de izquierda a derecha:

1. **Campo.** La finca, el dron, el transportador, el acopio y el puerto. Cada uno guarda lo que produce mientras no hay señal (store-and-forward) y lo sube cuando la recupera.
2. **Entrada a la nube.** Por cinco puertas, cada una con su control: IoT Core con certificado X.509 para la telemetría, el adaptador satelital para las fincas sin cobertura, API Gateway con Cognito para las apps, la VPN hacia el Transit Gateway para los acopios, y CloudFront con WAF para la consulta pública.
3. **Plataforma.** La VPC de producción con sus siete subredes, las colas, las funciones, DynamoDB, S3 y el servicio de inferencia.
4. **Cuentas transversales.** Red, con el Transit Gateway; seguridad, con la auditoría inmutable y las llaves; y la cuenta raíz, con las políticas y los presupuestos.

Las cajas marcadas **E6-01 a E6-08** son las que codifica la Épica 6. Son los mismos identificadores del plan de 100 horas.

Decisiones base

Decisión	Por qué	Detalle
AWS en `us-east-1`	IoT Core con certificado por dispositivo y revocación puntual, latencia competitiva desde Colombia por los cables del Caribe y todos los servicios del diseño disponibles	Briefing
`us-east-2` solo para la consulta del saco	El RTO de 4 horas lo exige solo la consulta; duplicar la ingesta no aporta	#15
Azure preparada, no construida	Rango de red reservado, conexión y DNS definidos, sin recursos ni costo	#10
Terraform y GitHub Actions con OIDC	`terraform plan` es lo que pide la Épica 6, y OIDC evita llaves de larga vida	Plan
Patrón de código: ingesta, finca patrón y función de confirmación del foco	Cubre el corazón del piloto: la lectura que termina en alerta y la foto que confirma la plaga	Briefing

2. Gobierno

Landing zone (#1). Seis cuentas en AWS Organizations:

Cuenta	Qué tiene
`AromaPacifico-Root`	Organización, SCP, IAM Identity Center y presupuestos. No aloja cargas
`AromaPacifico-Security`	Auditoría inmutable, GuardDuty, Config y llaves KMS

Cuenta	Qué tiene
`AromaPacifico-Network`	Transit Gateway, VPN de los acopios y Network Firewall
`AromaPacifico-Dev`	Desarrollo, `10.50.0.0/16`
`AromaPacifico-Test`	Pruebas, `10.60.0.0/16`
`AromaPacifico-Prod`	Producción, `10.70.0.0/16`; contingencia `10.71.0.0/16` en `us-east-2`

Desde la raíz se aplican cuatro SCP:

- `deny-unapproved-regions`: solo `us-east-1` y `us-east-2`.
- `protect-audit-and-security`: nadie apaga CloudTrail ni toca el bucket de auditoría.
- `deny-untagged-workload-resources`: no se crea un recurso sin las siete etiquetas.
- `deny-unencrypted-and-public-storage`.

Etiquetas. `FincaID`, `DronID`, `AcopioID`, `ViajeID`, `Ambiente`, `Propietario` y `Proyecto`. Alimentan el tablero de costo por fincas, drones, acopio, viajes y ambientes.

Presupuestos. USD 480 al mes en mes normal y USD 750 en cosecha. Avisan sin apagar la ingesta ni la consulta.

Auditoría (#2). Los cuatro eventos del enunciado van al bucket `aromapacifico-audit-logs-security`, con Object Lock en modo Compliance a 5 años:

Evento	Origen del registro
Lectura de un saco	Logs de acceso de la API
Cambio de un umbral	Registro de la aplicación con el `sub` de Cognito, cruzado con CloudTrail
Publicación de telemetría	Segunda acción de la regla de IoT
Entrega de un objeto de vuelo	Eventos de datos de S3

Ninguna identidad de producción puede borrarlos. Cuesta unos USD 53 al año.

Qué se conserva y qué se retira de 2020 (#3):

- **Se conservan** los requisitos de negocio: territorio, monitoreo con alerta, saco de 60 kg, viaje hasta Buenaventura, consulta por código, los cinco servicios de dron, las tres aplicaciones y la retención de 5 años.
- **Se retiran** los supuestos técnicos que ya no valen: la señal 2G/3G, el envío directo sin buffer y la infraestructura propia en el puerto.

3. Seguridad

Identidades (#4):

Quién	Se autentica con	MFA
Caficultor, transportador, operario de acopio, operador de drones y el agrónomo que autoriza la fumigación	**Amazon Cognito**	Obligatorio para el operario de acopio, el operador de drones y el agrónomo, con TOTP, que funciona sin señal
Comprador de solo lectura	Sin cuenta: consulta pública por código, protegida por WAF y límite de tasa	No aplica
Los operadores de la plataforma	**IAM Identity Center**	Obligatorio, con llave física FIDO2
Cada nodo de finca y cada dron	**Certificado X.509 propio en IoT Core**, con la llave privada en un elemento seguro	No aplica

Baja de un dispositivo. El certificado se pasa a `INACTIVE` y se desvincula de su política y de su cosa. Luego se verifica en tres capas que dejó de publicar: rechazo del handshake, ausencia de lecturas nuevas y conexión de prueba fallida.

Cifrado (#5):

- **En reposo:** cada almacén usa una llave KMS propia del dominio.
- **En tránsito:** la telemetría viaja por MQTT sobre mTLS; los objetos del dron, por HTTPS con URL prefirmada; los acopios, por IPsec. Nada viaja en claro.

Código del saco. Tiene la forma `SACO-AAAA-DEP-HASH8`. El `HASH8` sale de un HMAC-SHA-256 con una semilla que vive en KMS, así que sin esa semilla el código no se puede revertir ni a la cédula ni a la finca.

Qué ve cada perfil:

Perfil	Ve
Comprador	Origen, fechas de proceso, estado y variables de secado. Lee de la tabla separada `sacos_publicos`, que no tiene cédula, nombres, coordenadas ni ruta
Acopio	El viaje
Caficultor	Sus fincas

Datos personales. Salen del país bajo el artículo 26 de la Ley 1581 de 2012, con autorización expresa del titular en el ingreso al piloto. La cédula en claro no sale de Colombia y se conservan 5 años.

4. Red y conectividad

Los cinco puntos, con y sin señal

Detalle en #6.

Punto	Con señal	Sin señal
Finca	LTE-M o NB-IoT, MQTT sobre TLS a IoT Core, puerto 8883	Buffer en flash de hasta 24 horas, reintentos a 1, 5 y 15 minutos y drenado al reconectar. Solo se borra lo que la plataforma confirmó como persistido. Si la finca no tiene cobertura, usa Iridium SBD por satélite
Dron	La misión se descarga por HTTPS antes de salir. Los objetos suben desde la estación de la cuadrilla, por el wifi del acopio o por 4G	Ejecuta la misión ya autorizada y precargada. Sin bitácora persistida no hay cierre
Transportador	App con 4G y HTTPS a API Gateway con Cognito	Guarda una posición cada 5 minutos en SQLite cifrado y sube lotes al reconectar, sin duplicar
Acopio	LAN segmentada y VPN IPsec con dos túneles al Transit Gateway	La LAN, la impresión y la cola local siguen funcionando; se sincroniza al volver la WAN
Buenaventura	Solo se registra la entrega desde la app del transportador	Cola cifrada del teléfono hasta recuperar señal. No hay infraestructura de la Federación

Ninguna pieza depende de 2G ni de 3G.

Centro de acopio

Detalle en #8. Un solo patrón se repite en los tres departamentos cambiando el segundo octeto: 41 Cauca, 42 Huila y 43 Tolima.

- **Zonas:** siete VLAN, de la 101 a la 105 más la 110 y la 120, y cinco SSID, uno por cada zona con usuarios inalámbricos.
- **Visitantes:** se niega explícitamente su paso hacia gerencia y logística.
- **Capacidad:** 66 clientes a 2 Mbps de bajada piden 132 Mbps, más que los 100 Mbps del enlace. Por eso hay un techo de 90 Mbps y clases que reducen a transportadores y visitantes en el pico de cosecha.

Firewall

Detalle en #9. Una tabla única con ID estable por regla:

- **L01 a L30:** perímetro del acopio.
- **C01 a C22:** security groups.
- **N01 a N16:** NACL.

- **M01 a M07:** políticas de servicio.
- **T01 y T02:** reglas temporales, apagadas por defecto.

Solo la consulta pública y el ingreso de telemetría admiten origen `0.0.0.0/0`, y cada uno exige identidad o es de solo lectura. El módulo de seguridad de la Épica 6 genera las reglas permanentes desde este catálogo.

Direccionamiento y data paths

Detalle en #7.

Bloque	Uso
`10.50.0.0/16`	Desarrollo
`10.60.0.0/16`	Pruebas
`10.70.0.0/16`	Producción
`10.71.0.0/16`	Contingencia en `us-east-2`
`10.80.0.0/16`	Hub de red
`10.90.0.0/16`	Reservado para Azure

Ninguno se solapa con `10.41`, `10.42` ni `10.43.0.0/16`.

Cada VPC tiene siete subredes `/24` en dos zonas de disponibilidad:

Subred	Zona a	Zona b
Telemetría	`.1`	`.101`
Objetos de dron	`.2`	`.102`
Aplicación	`.10`	`.110`
Datos	`.20`	`.120`
Object storage	`.30`	`.130`
Administración	`.40`	`.140`
Consulta pública	`.50`	`.150`

Tres data paths separados:

- **Telemetría de finca:** IoT Core → cola → normalizador → DynamoDB.
- **Posición del transportador:** API Gateway → función → DynamoDB.
- **Objetos de dron:** estación → S3 por URL prefirmada o por el endpoint privado desde el acopio → función.

5. Automatización y cambio

Infraestructura como código (repositorio `iac`):

Elemento	Qué es	Caja
Repositorio base	Un estado remoto por cuenta, cifrado con KMS y con bloqueo; variables por ambiente sin secretos; pre-commit con gitleaks	E6-01
Módulo `network`	VPC y conexión con un acopio	E6-02, E6-03
Módulo `security`	Llaves, roles y reglas permanentes	E6-04
Módulos `ingest` y `farm`	Ingesta de telemetría y la finca patrón	E6-05, E6-06
Módulo `function`	Función de confirmación del foco	E6-07
Pipeline	GitHub Actions con OIDC	E6-08

El código instancia **una finca**, no las 200.

Pipeline (#26):

- En cada PR corre `fmt`, `validate`, TFLint y un escaneo de seguridad.
- Hay un `plan` por ambiente y la promoción va de desarrollo a pruebas y a producción.
- Producción exige revisores obligatorios.
- Un paso bloquea el `apply` en producción **entre las 05:00 y las 18:00 en semana de cosecha**, salvo con una etiqueta de incidente.

Secretos. No van en el repositorio ni en el estado. Los certificados de los nodos se crean desde un CSR generado en el elemento seguro, y el pipeline entra a AWS por OIDC.

Release notes. Las dos plantillas, de aplicación e infraestructura, se definen en la #32 y la #33.

6. Cargas

A. Monitoreo de finca

Detalle en #11 y #12.

El nodo:

- Un ESP32-S3 con módem LTE-M/NB-IoT y sondas de suelo, NPK, pH, aire y grano.
- Panel solar de 15 W y batería LiFePO4 de 12 V y 6 Ah, que aguanta tres días nublados seguidos.
- Se instala en una sola visita, de unas 4 h 30 min.

La ingesta:

- El cultivo se lee cada 4 horas y el secado cada hora.
- En cosecha son 10.800 registros al día y 324.000 al mes, contando las posiciones del transportador. Por eso se eligió DynamoDB On-Demand.
- Los umbrales viven en la plataforma y se cambian sin tocar el nodo, con versión y auditoría.

La alerta:

- Sale por SNS, por SMS y por push.
- Cuenta como entregada solo cuando la app confirma la recepción.
- Tiene un presupuesto de 300 segundos repartido por tramos.

B. Drones, de la plaga a la fumigación

Detalle en #13 y #14. Hay cinco servicios y ninguno reemplaza a otro: delimitar el lote, confirmar la alerta, fumigar, verificar y estimar la cosecha.

Modo combinado:

- **De área** para delimitar el lote y estimar la cosecha.
- **De precisión** para confirmar la alerta, fumigar y verificar.

Quién vuela: tres cuadrillas, una por acopio, bajo el RAC 100. Son unos 1.300 vuelos el primer año.

Flujo de la plaga a la fumigación:

1. Una lectura fuera de rango genera una alerta en la plataforma.
2. La cuadrilla vuela al punto del sensor y sube la foto.
3. La función de confirmación del foco invoca el servicio de inferencia y escribe el resultado en el expediente.
4. **El agrónomo autoriza la orden con MFA.** Ningún disparador la autoriza.
5. La misión se precarga con el polígono y las zonas de no vuelo, con un token válido por 48 horas.

6. Se fumiga, se sube la bitácora y la orden pasa a `VOLADA_REGISTRO_PERSISTIDO`.
7. A los 7 a 10 días se vuela la verificación, y la orden solo pasa a `CERRADA` con la bitácora y la foto.

C. Saco y viaje

Detalle en #15.

Estados: `EN_PREPARACION` → `EN_VIAJE_ACOPIO` → `EN_ACOPIO` (aceptado o rechazado) → `EN_VIAJE_PUERTO` → `ENTREGADO_PUERTO`. Cada evento lo genera un actor autenticado con Cognito, y se guardan en un almacén de eventos de solo agregar.

RPO de 15 minutos:

- DynamoDB Global Tables replica en segundos hacia `us-east-2`.
- PITR permite volver a cualquier punto de los últimos 35 días.
- S3 replica entre regiones con RTC.

RTO de 4 horas:

- La consulta pública cambia de región por Route 53 en menos de un minuto.
- La ingesta se levanta en `us-east-2` con Terraform en unos 75 minutos.

D. Centros de acopio

Ver la sección 4. Recepción e impresión:

- La etiqueta se imprime en el spooler local, sin depender de la WAN.
- Se reimprime siempre con el mismo código.
- La operación sigue con una cola cifrada por puesto cuando cae el enlace.

E. Funciones e inteligencia artificial

Detalle en #16 y #17.

Son cuatro funciones orientadas a eventos: confirmación del foco, verificación, estimación de cosecha y lote de telemetría. Cada una se invoca con un disparador y termina al persistir el resultado.

Invariante: si la invocación falla, el objeto de origen queda intacto y el estado del caso no cambia. Hay reintentos, una cola de fallos (DLQ) y una alarma.

Fotos con personas: antes de la inferencia, Rekognition `DetectFaces` y `DetectLabels` filtran las imágenes con personas. Esas imágenes no se envían a inferencia: van a cuarentena con Object Lock a 5 años.

> **Pendiente:** el servicio que diagnostica la hoja se está corrigiendo en los PR #56 y #57. Rekognition Custom Labels exige entrenar un modelo y cobra por hora encendida, y el enunciado prohíbe ambas cosas. Esta sección se cierra cuando se fusione esa corrección.

7. Observabilidad

Detalle en #18.

Qué se mide. Métricas, logs y trazas de cada capa, todo en CloudWatch y X-Ray.

Alarmas, con su destino:

Alarma	Destino
Finca sin telemetría (aviso a las 12 h, alarma a las 24 h)	`campo`
Alerta de cultivo no entregada	`ops-critical`
Vuelo sin registro persistido	`campo` y `ops`
Fumigación sin cierre	`campo`
Invocación fallida en la DLQ	`ops-critical` u `ops`
Enlace WAN caído	`ops-critical`

Los dos SLO:

- **Entrega de la alerta:** 95 % de las alertas con señal recibidas en menos de 5 minutos, en 28 días.
- **Disponibilidad de la consulta del saco:** 99,9 % al mes, medida también con un canario desde `us-east-2`.

Tableros. Uno operativo y uno de costo. El de costo usa una categoría de costo con cinco valores: pruebas, drones, acopio, fincas y plataforma compartida.

8. Sistema de diseño

El logo, la paleta con los estados del saco y la alerta de cultivo, la tipografía, los componentes y la lámina aplicada a las tres aplicaciones se desarrollan en las historias #35 a #38. No se hereda el manual de 2020.

9. Decisiones tomadas al consolidar

Al juntar los documentos aparecieron ocho puntos en que dos historias decían cosas distintas. Así quedan:

#	Tema	Decisión	Qué se ajusta
1	Entrada de la consulta pública: ALB (#5, #9) o CloudFront con API Gateway (#15)	**CloudFront con WAF delante de un ALB** en la subred de consulta pública, con una Lambda detrás que solo lee `sacos_publicos`. Se repite en `us-east-2` con conmutación por Route 53. Conserva la subred pública que pide el enunciado y las reglas C01 a C03 y N12 a N15 de la #9	En C01, el origen pasa de `0.0.0.0/0` a la lista de prefijos de CloudFront (`com.amazonaws.global.cloudfront.origin-facing`). En la #15, API Gateway se reemplaza por el ALB
2	Código del saco: HMAC en la app (#5) o cupo preasignado por acopio (#8)	**La plataforma genera el código HMAC** cuando el caficultor registra el saco. Si un saco llega al acopio sin código porque se registró sin señal, el acopio toma uno de un **cupo de códigos emitidos por la plataforma con el mismo formato**. Así no hay dos esquemas	La #8 aclara que su cupo son códigos HMAC emitidos por adelantado
3	Posición del transportador: `iot:Publish` (#4) o HTTPS (#6, #12)	**HTTPS a API Gateway con Cognito**	La matriz de la #4 se corrige en el módulo de seguridad (#23)
4	Impresión en el acopio: cola SQS (#4) o spooler local (#8)	**Spooler local**, que sigue funcionando sin WAN	La #4 retira `sqs:SendMessage` del operario de acopio en la #23
5	Regla de la función de lote de telemetría (#16 frente a #12)	La función consume de la **cola de la #12**, sin una regla de IoT propia	Corrección pedida en el PR #56
6	Eventos móviles no telemétricos (M03 de la #9)	Entran como eventos de campo, con origen `0.0.0.0/0`, Cognito, viaje autorizado y límite de tasa. Una allowlist de IP móviles no es viable	Se registra en el log de supuestos
7	Supuestos de la #6, #8, #9, #11 y #12 que solo estaban en sus documentos	Se pasan al registro de supuestos	`assumptions-log.md`
8	Diagramas de la #15 con operario portuario y agente aduanal de la Federación	En el puerto registra la entrega el transportador, como ya dice el texto	Pacheco actualiza los SVG

10. Documentos de detalle

Punto	Documentos
Gobierno	Landing zone · Auditoría · Matriz 2020
Seguridad	Identidades · Datos y saco
Red	Conectividad sin señal · Direccionamiento · Firewall · Segunda nube
Cargas	Nodo de finca · Ingesta · Servicio de drones · Orden de fumigación · Saco y viaje · Centro de acopio
Observabilidad	Observabilidad y SLO
Épica 6	Plan de 100 horas
Supuestos	Registro de supuestos